

CVE-2026-20223

Cisco Secure Workload REST API Unauthenticated Authentication Bypass

Vulnerability Intelligence Report | Published: 28 May 2026 | TLP: AMBER

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All content, findings, detection rules, and recommendations must be independently reviewed and validated by a qualified security professional before being acted upon or implemented in any environment.

Currency: Information is based on publicly available sources at the time of generation. Verify all details against the latest vendor advisories, NVD, and CISA guidance before relying on this document.

1. Executive Summary

CVE-2026-20223 is a maximum-severity (CVSS 10.0) authentication bypass vulnerability in Cisco Secure Workload, the company micro-segmentation and application dependency mapping platform. The flaw allows a completely unauthenticated remote attacker to access sensitive data and make arbitrary configuration changes with the privileges of the Site Admin role — the highest-privilege account in Secure Workload. Both SaaS and on-premises deployments are affected across all versions up to and including 4.0.x prior to the fixed releases.

The business impact of successful exploitation is critical. Cisco Secure Workload is a zero-trust segmentation control plane. Site Admin access enables an attacker to read the entire network topology and workload communication policies across all tenant environments, modify micro-segmentation rules to permit lateral movement that would otherwise be blocked, and exfiltrate sensitive workload metadata at scale. In multi-tenant deployments this extends to all customer environments on the shared platform simultaneously. The attack requires only network connectivity to the management API — no credentials, no user interaction, no special conditions.

Cisco has released patches (3.10.8.3 and 4.0.3.17) and explicitly confirmed no workarounds are available — upgrade is the only remediation. Cisco PSIRT reported no known in-the-wild exploitation at time of disclosure (approximately 20-22 May 2026), but given the CVSS 10.0 score and public advisory, rapid weaponisation by threat actors is expected. Organisations should treat this as a same-day emergency patch for any internet-facing or network-reachable Cisco Secure Workload management interfaces.

Attribute	Detail
CVE ID	CVE-2026-20223
Disclosure Date	~20-22 May 2026
Vulnerability Type	Authentication Bypass / Improper Access Control (CWE-306)
Affected Component	Cisco Secure Workload Cluster Software — Internal REST API
CVSSv3 Score	10.0 — CRITICAL
Attack Vector	Network (AV:N)
Attack Complexity	Low (AC:L)
Privileges Required	None (PR:N)
User Interaction	None (UI:N)
Scope	Changed (S:C) — cross-tenant impact

Exploit Status	No public PoC at time of publication — Cisco internal discovery
Zero-Day	No — patch released concurrently with disclosure
Patch Available	Yes — v3.10.8.3 and v4.0.3.17 — NO WORKAROUND EXISTS

2. Vulnerability Details

2.1 Root Cause

CVE-2026-20223 is caused by insufficient validation and authentication on certain internal REST API endpoints within the Cisco Secure Workload Cluster Software. The affected endpoints are intended for internal inter-component communication but are reachable from external network interfaces without enforcing the standard authentication controls applied to user-facing API surfaces.

The vulnerability is classified as CWE-306: Missing Authentication for Critical Function. Affected endpoints expose privileged Site Admin operations and process unauthenticated requests with Site Admin execution context. Rather than enforcing token-based or certificate-based authentication, the affected code path allows requests that reach these endpoints to be processed unconditionally. The exact vulnerable endpoint paths and request parameters have not been publicly disclosed by Cisco, consistent with responsible disclosure practice to reduce exploitation risk during the patching window.

The vulnerability affects both SaaS-hosted and self-managed on-premises deployments, indicating the flaw is in the core application software rather than a deployment-specific configuration issue. The scope is marked Changed in CVSS because a successful attack crosses tenant isolation boundaries, allowing one attacker to impact all tenants sharing the Secure Workload instance.

2.2 Affected Products

Product / Deployment	Affected Versions	Fixed Version	Status
Cisco Secure Workload (SaaS)	All versions 3.9 and earlier	Migrate to 3.10.8.3 or 4.0.3.17	VULNERABLE
Cisco Secure Workload (On-Premises)	All versions 3.9 and earlier	Migrate to 3.10.8.3 or 4.0.3.17	VULNERABLE
Cisco Secure Workload 3.10.x	3.10.0 through 3.10.8.2	3.10.8.3	VULNERABLE — patch available
Cisco Secure Workload 4.0.x	4.0.0 through 4.0.3.16	4.0.3.17	VULNERABLE — patch available
Cisco Secure Workload 3.10.8.3+	3.10.8.3 and later	N/A	Not affected
Cisco Secure Workload 4.0.3.17+	4.0.3.17 and later	N/A	Not affected

2.3 Attack Scenarios

Scenario 1 — Unauthenticated Cross-Tenant Data Exfiltration: A threat actor with network access to the Cisco Secure Workload management plane (typically TCP 443 on the cluster VIP or SaaS endpoint)

crafts a REST API request to an internal endpoint without providing authentication credentials. The API processes the request with Site Admin privilege and returns sensitive workload telemetry, application dependency maps, and micro-segmentation policy data from all tenants on the platform. In a managed service or multi-tenant environment this exposes all customer environments simultaneously in a single unauthenticated request chain.

Scenario 2 — Micro-Segmentation Policy Manipulation: An attacker exploiting CVE-2026-20223 modifies Cisco Secure Workload segmentation enforcement policies via the unauthenticated API, adding permit rules that allow lateral movement between previously isolated workload groups. This creates persistent stealth access paths through the network that bypass zero-trust controls and are invisible to network monitoring tools operating below the segmentation policy layer.

Scenario 3 — Reconnaissance Acceleration via Topology Enumeration: A threat actor performing reconnaissance identifies an exposed Cisco Secure Workload management interface via internet scanning (Shodan, Censys). They leverage CVE-2026-20223 to enumerate the complete internal network topology, workload IP addresses, communication dependency maps, and segmentation policy details. This intelligence dramatically accelerates subsequent intrusion campaigns by eliminating the discovery phase of the kill chain on any network protected by the compromised Secure Workload instance.

2.4 CVSS v3.1 Breakdown

Metric	Value	Rationale
Attack Vector	Network (N)	Exploitable from any network location that can reach the management API — no local access required
Attack Complexity	Low (L)	No special conditions, race windows, or target-specific knowledge needed beyond network access
Privileges Required	None (N)	Zero authentication — attacker sends unauthenticated HTTP request with no credentials
User Interaction	None (N)	Fully server-side exploitation; no victim action required at any stage
Scope	Changed (C)	Attack crosses tenant isolation boundaries, impacting all tenants on the platform
Confidentiality	High (H)	All sensitive workload data, topology, and tenant configurations accessible
Integrity	High (H)	Attacker can modify segmentation policies and configurations across all tenants
Availability	High (H)	Attacker could disrupt platform operations and segmentation enforcement platform-wide

3. Threat Landscape & Context

CVE-2026-20223 achieves the maximum CVSS score of 10.0 — a threshold reached by fewer than 1% of publicly disclosed CVEs. The combination of network-accessible attack vector, zero authentication requirement, and cross-tenant scope places this among the most dangerous enterprise infrastructure vulnerabilities of 2026. The attack surface is particularly concerning because Cisco Secure Workload management interfaces are sometimes exposed on corporate networks or cloud VPCs under the assumption that authentication alone provides sufficient access control.

Cisco Secure Workload is deployed in large enterprise, financial services, healthcare, and government environments as a critical security control layer. Compromise of the platform does not merely expose data — it actively undermines the zero-trust segmentation controls protecting the entire application estate. An attacker with Site Admin access can surgically remove the segmentation rules that would otherwise detect or block lateral movement, effectively blinding the network security posture from the inside.

The vulnerability was discovered during Cisco internal security testing rather than by an external researcher, suggesting no current weaponised exploit exists in threat actor toolkits at time of publication. However, the advisory provides sufficient architectural context for skilled actors to develop exploits independently. Based on precedent with comparable Cisco CVSS 10.0 disclosures — notably CVE-2023-20198 in IOS XE (weaponised within 48 hours) — rapid exploitation attempts are expected within 2-7 days of advisory publication. CISA KEV listing should be anticipated.

The explicit Cisco confirmation that no workaround exists is operationally significant. Unlike most CVEs where network controls or configuration changes provide partial compensating controls, this vulnerability has only one remediation: the vendor patch. Organisations cannot mitigate this through configuration alone.

4. Mitigation

4.1 Apply the Vendor Patch (Only Remediation Available)

IMPORTANT: Cisco has explicitly confirmed there are NO workarounds for this vulnerability. Upgrade is the only path to remediation. Fixed versions:

Current Version Track	Action Required	Target Version
3.9 and earlier	Direct migration required	3.10.8.3 or 4.0.3.17
3.10.x below 3.10.8.3	In-track upgrade	3.10.8.3
4.0.x below 4.0.3.17	In-track upgrade	4.0.3.17

Reference Cisco Security Advisory: [cisco-sa-csw-pnbsa-g8WEnuy](#). Follow the Cisco Secure Workload upgrade documentation for your deployment topology. SaaS customers should contact Cisco TAC to confirm their hosted instance patch status and expected update window.

4.2 Interim Risk Reduction — Network Isolation

While not a fix, restricting network access to the Cisco Secure Workload management plane dramatically reduces attacker reachability. This is a compensating control only — do not treat it as equivalent to patching:

```
# Restrict CSW management interface (TCP 443) to authorised admin source  
IPs  
# Apply at perimeter firewall, cloud security group, or network ACL  
  
# Verify current exposure — scan from an external perspective
```

```
nmap -sS -p 443,8080,8443 <CSW_cluster_VIP> --reason  
  
# Cloud security group example (AWS CLI)  
aws ec2 authorize-security-group-ingress --group-id sg-XXXXX \  
--protocol tcp --port 443 --cidr <ADMIN_IP_RANGE>/32
```

4.3 Privileged Account Review

While awaiting patch deployment, audit all Site Admin accounts and API keys in Cisco Secure Workload. Revoke all non-essential Site Admin API keys. Review recent API activity logs for evidence of anomalous activity that may have occurred before the vulnerability was disclosed. Document the complete list of authorised Site Admin users and API keys to establish a clean baseline for post-patch verification.

5. Detection

5.1 Behavioural Indicators

Key indicators of CVE-2026-20223 exploitation include: REST API requests to Cisco Secure Workload internal endpoints (paths containing /api/v1/admin, /api/v1/site, or /internal/api) originating from source IPs not in the authorised admin allow-list; API activity returning HTTP 2xx responses with no associated authenticated session or user context; Site Admin operations in the audit trail with no corresponding admin login event; cross-tenant API calls visible in the access logs; configuration changes to segmentation policies or tenant settings not correlated to a change management record.

Post-exploitation indicators include: bulk export or enumeration of network policy configs, workload metadata, or tenant data; new permit policies added to previously deny-all segmentation groups; new Site Admin API keys or user accounts created outside of normal provisioning processes; unusual volumes of API calls enumerating workload labels, IP addresses, or flow telemetry; outbound data transfers from the Secure Workload cluster to external IP addresses.

5.2 Sigma Rule — Unauthenticated API Access

```
title: Cisco Secure Workload Unauthenticated REST API Access (CVE-2026-20223)  
id: b7c3d2e1-4f5a-6b7c-8d9e-0f1a2b3c4d5e  
status: experimental  
description: >  
  Detects unauthenticated or anomalous access to Cisco Secure Workload  
internal  
  REST API endpoints indicative of CVE-2026-20223 exploitation.  
references:  
  -  
  https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-csw-pnbsa-g8WEnuy  
  - https://nvd.nist.gov/vuln/detail/CVE-2026-20223  
author: Lost Boys Cyber  
date: 2026-05-28  
tags:  
  - attack.initial_access  
  - attack.t1190  
  - attack.privilege_escalation  
  - attack.t1078.004
```

```

logsource:
  category: webserver
  product: cisco_secure_workload
detection:
  selection_admin_nologin:
    cs-status: "200"
    cs-uri-stem|contains:
      - "/api/v1/admin"
      - "/api/v1/site"
      - "/internal/api"
    cs-username: "-"
  selection_recon:
    cs-status|startswith: "20"
    cs-uri-stem|contains: "/api/v1/admin"
    c-ip|cidr: "0.0.0.0/0"
  filter_known_admin:
    c-ip|cidr:
      - "10.0.0.0/8"
  condition: (selection_admin_nologin or selection_recon) and not
  filter_known_admin
falsepositives:
  - Internal health checks from cluster nodes (tune with known cluster IP
  CIDRs)
  - Misconfigured monitoring or automation agents
level: critical

```

5.3 Application / Network Log Indicators

Source	Indicator	Detection Value
CSW API access logs	HTTP 2xx to admin endpoints from non-admin source IPs	Critical
CSW audit trail	Site Admin operations with no correlated login event	Critical
CSW audit trail	API key created by system/service account without change ticket	High
CSW audit trail	Bulk export of policy, workload, or tenant data	High
CSW audit trail	Segmentation policy changes outside change management window	Critical
Network flow logs	New external source IPs connecting to CSW mgmt port 443/8443	Medium
SIEM correlation	Site Admin API operations > threshold per minute from single source	High

5.4 Microsoft Sentinel / Splunk Detection Queries

```
// Sentinel KQL – Cisco Secure Workload anomalous API access
// Requires CSW API logs ingested via Syslog CEF or custom connector
CommonSecurityLog
| where DeviceProduct has "Secure Workload"
| where RequestURL has_any ("/api/v1/admin", "/api/v1/site",
"/internal/api")
| where SourceIP !in (split("<ADMIN_IP_1>,<ADMIN_IP_2>", ",")) // Replace
with your admin IPs
| where EventOutcome == "Success"
| project TimeGenerated, SourceIP, DestinationIP, RequestURL,
SourceUserName, EventOutcome, Message
| order by TimeGenerated desc
```

```
// Splunk SPL – unauthenticated Site Admin activity
index=csw_logs sourcetype="cisco:secure_workload:api"
| where status=200 AND (uri_path="/api/v1/admin*" OR
uri_path="/api/v1/site*")
| where NOT src_ip IN ("10.0.0.0/24")
| where user="-" OR user=""
| stats count by _time, src_ip, uri_path, user
| sort -count
```

5.5 YARA Rule

No file-based malware is associated with this vulnerability at publication time. The following rule targets tools or scripts containing strings indicative of CVE-2026-20223 exploit development:

```
rule CVE_2026_20223_ExploitTool {
  meta:
    description = "Detects scripts or tools targeting CVE-2026-20223
Cisco Secure Workload auth bypass"
    author      = "Lost Boys Cyber"
    date        = "2026-05-28"
    reference   =
"https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvis
ory/cisco-sa-csw-pnbsa-g8WEnuy"
    severity    = "critical"
  strings:
    $s1 = "CVE-2026-20223" ascii wide nocase
    $s2 = "cisco-sa-csw-pnbsa" ascii nocase
    $s3 = "Secure Workload" ascii wide nocase
    $s4 = "/api/v1/admin" ascii
    $s5 = "site_admin" ascii nocase
    $s6 = "X-Tetration-Oper-User" ascii
  condition:
    (2 of ($s1, $s2, $s3)) or ($s4 and $s5 and $s6)
}
```


6. Threat Hunting

Because CVE-2026-20223 is an unauthenticated API bypass, hunting focuses on Cisco Secure Workload control-plane access logs and network telemetry rather than endpoint data. Run these hunts across at least 30 days of historical data.

6.1 Hunt: Unauthenticated API Activity Against CSW Endpoints

Hypothesis: If CVE-2026-20223 was exploited, we will see HTTP 200-series responses from Cisco Secure Workload internal API endpoints requested by source IPs not in the authorised admin range, with no authentication token or username present in the request context.

Data sources required: CSW API access logs, CSW audit trail, network proxy/firewall logs, SIEM.

```
// Splunk SPL – hunt for unauthenticated access to admin endpoints
index=csw_logs earliest=-30d
| where status IN ("200","201","204")
| where uri_path IN ("/api/v1/admin*", "/api/v1/site*", "/internal*")
| where NOT cidrmatch("10.0.0.0/24", src_ip)
| where user="-" OR isnull(user)
| table _time, src_ip, uri_path, status, user, bytes
| sort -_time
```

6.2 Hunt: Unexpected Site Admin Operations

Hypothesis: Successful exploitation grants Site Admin access. We should see administrative operations that cannot be correlated to a known authenticated admin session in the same time window.

```
index=csw_audit earliest=-30d
| where event_type IN
("policy_change", "tenant_config", "user_create", "api_key_create", "scope_change")
| join type=left user [ search index=csw_audit event_type="user_login" |
fields user, _time | rename _time as login_time ]
| where isnull(login_time) OR ((_time - login_time) > 3600)
| table _time, src_ip, user, event_type, details
```

6.3 Hunt: New Source IPs Accessing CSW Management Interface

Hypothesis: An attacker will originate from a source IP that has never previously accessed the CSW management interface or is outside the defined admin CIDR range.

```
// Network flow hunt – new IPs connecting to CSW management port
index=network_flows dest_port=443 dest_ip=<CSW_VIP> earliest=-30d
| stats earliest(_time) as first_seen, count by src_ip
| where first_seen > relative_time(now(), "-7d")
| where NOT cidrmatch("10.0.0.0/24", src_ip)
| sort -count
```

7. MITRE ATT&CK Mapping

Tactic	Technique / Sub-Technique	Relevance to CVE-2026-20223
Initial Access	T1190 — Exploit Public-Facing	Primary exploitation vector —

	Application	unauthenticated request to exposed management plane API
Privilege Escalation	T1078.004 — Valid Accounts: Cloud Accounts	Attacker obtains Site Admin role context without valid credentials
Discovery	T1580 — Cloud Infrastructure Discovery	Site Admin access enables enumeration of all workloads, labels, topology, and policies
Collection	T1530 — Data from Cloud Storage Object	Exfiltration of workload policy configs, dependency maps, and tenant metadata
Impact	T1565.001 — Data Manipulation: Stored Data Manipulation	Modification of segmentation policies to permit lateral movement across workload groups
Defense Evasion	T1556 — Modify Authentication Process	Attacker may modify API authentication settings post-exploitation to maintain access
Lateral Movement	T1599 — Network Boundary Bridging	Segmentation policy manipulation allows movement across previously isolated workload groups
Persistence	T1098 — Account Manipulation	Creation of backdoor Site Admin API keys or user accounts for persistent platform access

8. Recommended Actions Summary

Priority	Action	Owner	Timeline
P1 — Critical	Upgrade to Cisco Secure Workload 3.10.8.3 or 4.0.3.17 immediately	IT / Cisco Admin	Same day
P1 — Critical	Restrict CSW management interface to admin IPs via ACL/firewall	Network / Security Ops	Within 24 hours
P1 — Critical	Audit all Site Admin API keys — revoke all non-essential keys	Cisco Admin Team	Within 24 hours
P2 — High	Deploy SIEM detection rules for unauthenticated API access	SOC / Detection Eng.	Within 48 hours

P2 — High	Run 30-day retrospective hunt for unauthorised API access	Threat Hunt Team	Within 72 hours
P2 — High	Review all segmentation policy changes since 1 May 2026	Cisco Admin / Security	Within 72 hours
P2 — High	Verify SaaS instance patch status with Cisco TAC (SaaS customers)	SaaS customers	Within 24 hours
P3 — Medium	Enable CSW audit log forwarding to SIEM if not already active	SOC / SIEM Team	Within 1 week
P3 — Medium	Document authorised admin source IPs for ongoing API access allow-listing	Network / Security	Within 1 week
P3 — Medium	Update YARA and TI feeds with exploit tool hashes as PoC code emerges	Threat Intel	As available

9. References

- [1] Cisco PSIRT. "Cisco Secure Workload Unauthorized API Access Vulnerability — cisco-sa-csw-pnbsa-g8WEnuy." <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-csw-pnbsa-g8WEnuy>
- [2] NVD. "CVE-2026-20223 Detail." <https://nvd.nist.gov/vuln/detail/CVE-2026-20223>
- [3] The Hacker News. "Cisco Patches CVSS 10.0 Secure Workload REST API Flaw Enabling Data Access." <https://thehackernews.com/2026/05/cisco-patches-cvss-100-secure-workload.html>
- [4] SOCRadar. "CVE-2026-20223: Cisco Secure Workload Auth Bypass Grants Site Admin Access." <https://socradar.io/blog/cve-2026-20223-cisco-secure-workload-auth-bypass/>
- [5] Vulert. "CVE-2026-20223 Cisco Secure Workload REST API Flaw Enables Sensitive Data Access." <https://vulert.com/blog/cve-2026-20223-cisco-secure-workload-rest-api-flaw/>
- [6] Security Online. "CVSS 10.0 Alert: Critical Cisco Secure Workload Exploit Grants Unauthenticated Site Admin Access." <https://securityonline.info/cisco-secure-workload-api-vulnerability-cve-2026-20223-cvss-10/>
- [7] The Cyber Express. "Cisco Fixes CVE-2026-20223 Secure Workload API Flaw." <https://thecyberexpress.com/cisco-cve-2026-20223/>
- [8] CVETodo. "CVE-2026-20223 | Cisco Secure Workload | Critical." <https://cvetodo.com/cve/CVE-2026-20223>
- [9] MITRE ATT&CK. "T1190 — Exploit Public-Facing Application." <https://attack.mitre.org/techniques/T1190/>

[10] MITRE ATT&CK. "T1078.004 — Valid Accounts: Cloud Accounts."
<https://attack.mitre.org/techniques/T1078/004/>